



INFORME EJECUTIVO DE AUTOEVALUACIÓN

Cumplimiento LOPDP · Madurez Institucional · Gobernanza Tecnológica

INSTITUCIÓN D

Tipo de Institución	Fiscal
Responsable de la autoevaluación	XXXXXXX
Cargo	DELEGADO PDP
Fecha de aplicación	2026-08-14
Revisado por	PEDRO VALVERDE

INDICADORES CLAVE

CUMPLIMIENTO LOPDP

12.1%

MADUREZ INSTITUCIONAL

1.1 / 5

GOBERNANZA TI

1.8%

ÍNDICE DE CUMPLIMIENTO GLOBAL

11.8%

Riesgo Alto — Acción inmediata

1. Resumen por módulo

Módulo	% Cumplimiento / Madurez	Sí	Parcial	No
Módulo 1 · Cumplimiento LOPDP/RGLOPDP	12.1%	2	3	24
Módulo 2 · Madurez Institucional	1.1 / 5 (21.6%)	—	—	—
Módulo 3 · Gobernanza Tecnológica	1.8%	0	1	27

2. Hallazgos principales — criterios no cumplidos

Módulo	ID	Criterio
Módulo 1	A1	¿La institución ha identificado y registrado todas las bases de datos que contienen datos personales?
Módulo 1	A3	¿Se documenta el período de conservación de los datos conforme a minimización y proporcionalidad?
Módulo 1	A4	¿Existe un inventario actualizado de flujos de datos (quién recibe, quién envía, con qué propósito)?
Módulo 1	B1	¿Se informa al titular sobre qué datos se recopilan, cómo se usan y con quién se comparten?
Módulo 1	B2	¿Se obtiene el consentimiento explícito antes de recopilar o procesar datos personales?
Módulo 1	B5	¿Cuenta con política de uso de cookies con consentimiento informado?
Módulo 1	C1	¿Existe un mecanismo formal para atender solicitudes de Acceso a datos personales?
Módulo 1	C2	¿Existe un mecanismo formal para solicitudes de Rectificación de datos?
Módulo 1	C3	¿Existe un mecanismo formal para solicitudes de Cancelación / Supresión de datos?
Módulo 1	C4	¿Existe un mecanismo formal para solicitudes de Oposición al tratamiento?
Módulo 1	D2	¿Cuenta con contratos firmados con encargados de tratamiento externos?
Módulo 1	D3	¿Tiene acuerdos de confidencialidad firmados con encargados y colaboradores que acceden a datos?
Módulo 1	D4	¿Se verifica que los encargados externos cumplen con la LOPDP?
Módulo 1	E1	¿Cuenta con medidas de seguridad técnicas y organizativas para proteger datos personales?
Módulo 1	E2	¿Realiza análisis de riesgos que incluya el tratamiento de datos personales?
Módulo 1	E3	¿Se realiza Evaluación de Impacto en Protección de Datos (EIPD) para tratamientos de alto riesgo?
Módulo 1	E4	¿Mantiene un procedimiento documentado para notificación de vulneraciones de seguridad?
Módulo 1	E5	¿Realiza análisis de vulnerabilidades informáticas relacionadas con datos personales?
Módulo 1	E6	¿Cuenta con políticas de anonimización, cifrado y eliminación segura de datos?
Módulo 1	E7	¿Tiene señalización visible en zonas con cámaras de seguridad?
Módulo 1	F1	¿Se realizan capacitaciones periódicas a docentes, autoridades, estudiantes sobre protección de datos?
Módulo 1	F2	¿Se realizan revisiones periódicas y auditorías de cumplimiento de protección de datos?
Módulo 1	F3	¿Se ha documentado y aplica una política de retención y eliminación de datos?
Módulo 1	F4	¿Se realizan pruebas de penetración o análisis de seguridad informática?
Módulo 3	TG1	¿Existe un plan estratégico de tecnología de la información (PETI) vigente y alineado al plan institucional?

Módulo	ID	Criterio
Módulo 3	TG2	¿Hay una unidad o responsable formal de TI con funciones y presupuesto definidos?
Módulo 3	TG3	¿Existe un comité o instancia de toma de decisiones tecnológicas en la institución?
Módulo 3	TG4	¿Se aplica algún marco de referencia para gobernanza TI (COBIT, ITIL, ISO 38500, ISO 27001 u otro)?
Módulo 3	TA2	¿Se cuenta con un inventario actualizado de software y licencias?
Módulo 3	TA3	¿Están identificados y clasificados los sistemas de información por criticidad?
Módulo 3	TA4	¿Se gestiona el ciclo de vida de los activos tecnológicos (adquisición, operación, baja)?
Módulo 3	SI1	¿Los sistemas de información institucionales están documentados (arquitectura, flujos de datos, usuarios)?
Módulo 3	SI2	¿Existe integración entre los sistemas de información? ¿Están documentados los flujos de integración?
Módulo 3	SI3	¿Los sistemas aplican controles de acceso basados en roles (RBAC) o perfiles de usuario?
Módulo 3	SI4	¿Se registran logs de auditoría en los sistemas de información (accesos, cambios, consultas)?
Módulo 3	SI5	¿Los sistemas de información críticos cuentan con planes de continuidad o contingencia?
Módulo 3	SI6	¿Se realizan respaldos periódicos de bases de datos y sistemas con pruebas de restauración?
Módulo 3	SEC1	¿Existe una política de seguridad de la información documentada y vigente?
Módulo 3	SEC2	¿Se aplica gestión de parches y actualizaciones de seguridad en sistemas operativos y aplicaciones?
Módulo 3	SEC3	¿Se usan herramientas de protección perimetral (firewall, antivirus, IDS/IPS)?
Módulo 3	SEC4	¿Existe segmentación de redes y control de acceso a la infraestructura?
Módulo 3	SEC5	¿Se gestiona formalmente el control de accesos privilegiados (administradores de sistemas)?
Módulo 3	SEC6	¿Se realizan pruebas de seguridad (pentesting, ethical hacking) periódicamente?
Módulo 3	SV1	¿Existe un sistema de gestión de incidentes y solicitudes TI (mesa de ayuda / help desk)?
Módulo 3	SV2	¿Se miden los tiempos de respuesta y resolución de incidentes tecnológicos?
Módulo 3	SV3	¿Existen Acuerdos de Nivel de Servicio (SLA) con proveedores tecnológicos críticos?
Módulo 3	SV4	¿Existe gestión de cambios formalizada para modificaciones en sistemas productivos?
Módulo 3	CN1	¿La gestión de TI está alineada con la Ley de Comercio Electrónico, Firmas y Mensajes de Datos?
Módulo 3	CN2	¿Se aplica el Esquema Gubernamental de Seguridad de la Información (EGSI) o similar?
Módulo 3	CN3	¿Los sistemas de información consideran requisitos de protección de datos desde su diseño (privacy by design)?
Módulo 3	CN4	¿Se realiza revisión periódica del cumplimiento normativo tecnológico (auditorías TI)?

Dimensiones de madurez con nivel bajo (nivel 1-2)

ID	Dimensión	Nivel
G1	Existe una estructura de gobierno de datos con roles y responsabilidades definidos (Responsable, DPD, Encargados).	1
G2	La alta dirección lidera y está comprometida con el cumplimiento normativo en protección de datos.	2
G3	Existen políticas institucionales formalizadas sobre privacidad y protección de datos personales.	1
G4	Se cuenta con presupuesto asignado para actividades de cumplimiento y protección de datos.	1

ID	Dimensión	Nivel
P1	Los procesos de tratamiento de datos están documentados, aprobados y comunicados al personal.	1
P2	Existe un registro de actividades de tratamiento (RAT) actualizado.	1
P3	Se aplican procedimientos formales para responder derechos ARCO+ de los titulares.	1
P4	Se dispone de procedimientos para gestión de incidentes y brechas de datos.	1
P5	Existe un proceso de revisión y mejora continua de los procedimientos de protección de datos.	1
CC1	El personal tiene conocimiento básico de la LOPDP y sus obligaciones.	1
CC2	Se realizan capacitaciones formales y periódicas sobre protección de datos a todos los niveles.	1
CC3	Existe una cultura de privacidad por diseño en el desarrollo de nuevos proyectos o sistemas.	1
CC4	El incumplimiento de normas de privacidad tiene consecuencias formales (régimen disciplinario).	2
R1	Se realiza análisis de riesgos formal para el tratamiento de datos personales.	1
R2	Los riesgos identificados tienen controles asignados, responsables y plazos de mitigación.	1
R3	Se aplican Evaluaciones de Impacto en Protección de Datos (EIPD) cuando corresponde.	1
R4	Las medidas de seguridad técnica (cifrado, control de acceso, logs) están implementadas y documentadas.	1
R5	Se realizan pruebas periódicas de seguridad (pentesting, análisis de vulnerabilidades).	1
T1	Los contratos con proveedores incluyen cláusulas de protección de datos.	1
T2	Se verifica que los encargados externos cumplen con estándares equivalentes de protección de datos.	1
T3	Existe un registro actualizado de encargados de tratamiento externos.	1
A1	Se realizan auditorías internas periódicas de cumplimiento en protección de datos.	1
A2	Existen indicadores y métricas de cumplimiento que se monitorean regularmente.	1
A3	Los hallazgos de auditoría se documentan, priorizan e implementan con seguimiento.	1
A4	La institución aplica un ciclo de mejora continua (PHVA) en la gestión de datos personales.	1

3. Hoja de ruta por módulo

Cada módulo se interpreta de forma independiente según el rango de cumplimiento alcanzado. El resultado indica qué debe lograr la institución en esa etapa y las acciones concretas para avanzar al siguiente rango.

MÓDULO 1 · Cumplimiento LOPDP/RGLOPDP

12.1% · Rango 0%–30% · Cumplimiento inicial / brechas críticas

Qué debe lograr	Construir la base jurídica y documental de protección de datos.
Acciones prioritarias	1) Identificar bases y tratamientos. 2) Levantar RAT. 3) Definir finalidades y conservación. 4) Identificar bases de legitimación. 5) Aprobar política y avisos. 6) Designar DPD cuando corresponda. 7) Crear procedimiento de derechos. 8) Crear procedimiento de incidentes. 9) Identificar encargados y contratos. 10) Levantar riesgos y medidas mínimas de seguridad.
Entregables principales	RAT inicial; inventario de bases; matriz de legitimación; política de privacidad; avisos; nombramiento DPD; RACI; procedimiento ARCO+; procedimiento incidentes; matriz de encargados; contratos; tabla de conservación; matriz inicial de riesgos; plan de capacitación.
Indicadores de salida	100% tratamientos críticos identificados; roles críticos formalizados; procedimientos esenciales aprobados.
Prioridad	CRÍTICA
Responsables sugeridos	Dirección + DPD + Jurídico + TI + áreas
Criterio para avanzar de rango	No existen tratamientos críticos sin identificar ni procesos esenciales sin responsable/procedimiento.

MÓDULO 2 · Madurez Institucional

21.6% · Rango 0%–30% · Madurez inicial / ad hoc

Qué debe lograr	Pasar de prácticas aisladas a una estructura mínima de gobierno y procesos.
Acciones prioritarias	1) Definir estructura de gobierno. 2) Formalizar roles. 3) Aprobar políticas. 4) Documentar procesos. 5) Crear RAT. 6) Crear procedimientos de derechos/incidentes. 7) Capacitación básica. 8) Metodología de riesgos. 9) Controles básicos a terceros. 10) Crear registro de hallazgos.
Entregables principales	Organigrama/RACI; política; mapa de procesos; RAT; procedimientos; plan de capacitación; metodología de riesgos; matriz de terceros; registro de hallazgos.
Indicadores de salida	Roles definidos; procesos críticos documentados; capacitación inicial; riesgos críticos identificados.
Prioridad	CRÍTICA
Responsables sugeridos	Dirección + DPD + dueños de proceso
Criterio para avanzar de rango	La institución deja de operar de manera informal.

MÓDULO 3 · Gobernanza Tecnológica

1.8% · Rango 0%–30% · Gobernanza TI inicial / brechas críticas

Qué debe lograr	Establecer control mínimo sobre tecnología que trata datos personales.
Acciones prioritarias	1) Definir responsable/unidad TI. 2) Inventariar hardware/software. 3) Clasificar sistemas críticos. 4) Documentar sistemas y flujos. 5) Aprobar política de seguridad. 6) Establecer controles de acceso. 7) Crear respaldos. 8) Crear mesa de ayuda. 9) Identificar requisitos normativos. 10) Iniciar Privacy by Design.
Entregables principales	PETI/plan TI inicial; organigrama TI; inventario de activos; catálogo de sistemas; diagramas de flujos; política de seguridad; matriz de accesos; procedimiento de respaldos; help desk; matriz de requisitos legales.
Indicadores de salida	100% sistemas críticos identificados; activos críticos con propietario; controles críticos definidos.
Prioridad	CRÍTICA
Responsables sugeridos	Dirección + TI + DPD
Criterio para avanzar de rango	No existen sistemas críticos desconocidos ni controles básicos ausentes.

Este informe fue generado automáticamente a partir de las respuestas registradas en el Instrumento de Autoevaluación Institucional. La hoja de ruta por módulo proviene del Modelo de Madurez LOPDP institucional. Para el detalle completo de los 82 criterios evaluados, consulte el archivo Excel adjunto.

4. Formato de consentimiento digital

1.1.1. FORMATO DE CONSENTIMIENTO DIGITAL

1. ACEPTACIÓN

Declaro que he leído y comprendido la información contenida en el presente consentimiento informado y que he sido informado/a de manera clara, suficiente y comprensible sobre el tratamiento de mis datos personales.

- ☐ ACEPTO el tratamiento de mis datos personales para las finalidades descritas en el presente consentimiento informado.
- ☐ ACEPTO el uso de imagen, fotografía y/o material audiovisual, cuando aplique.
- ☐ ACEPTO el tratamiento de datos sensibles, cuando aplique.

La aceptación otorgada será registrada electrónicamente por la plataforma utilizada, conservando la evidencia necesaria para acreditar la identidad o autenticación del usuario, así como la fecha, hora y demás registros asociados a la manifestación de voluntad realizada.

EVIDENCIA DE REGISTRO ELECTRÓNICO

Usuario: XXXXXXXXXXXXXXXX · Cargo: DELEGADO PDP

Fecha: 14/8/2026 · Hora: 7:45:36 p. m.

Estado del consentimiento: Completo